INFORMATION TECHNOLOGY AUDIT REPORT
N-VISION
Professional Audit Report - Increment 4
Lab 10: Control Assessment and Gap Analysis

Audit Team / Group No.	N-VISION Audit Team | [Group number - confirm]
Capstone System / Build	N-VISION: A Data-Driven Ticketing System for Optimized Anti-Rabies Vaccination Management | v1.0 | pilot deployment, Mandaluyong City ABTC (as stated in Lab 8; build and environment to be confirmed - REC-09-08)
Partner Organization	Mandaluyong City Animal Bite Treatment Center (ABTC) / Mandaluyong City Health Office, Mandaluyong City LGU
Member 1 / Role	Edmar A. Isidro | Control Assessment Lead
Member 2 / Role	Celso L. Daclis | Application and Access Control Tester
Member 3 / Role	Alvin T. Tinaan | Governance, Privacy, and Recovery Tester
Prior Approved Version	Lab 9 report version 0.3 / [approval date]
Current Version / Date	Version 0.4 | [preparation date] | [submission date]
Audit / Evidence Cutoff	[Confirm date and time] - design-stage evidence carried from Labs 8 and 9; evidence from Lab 10 tests is dated and logged as EVD-10-xx when each test is performed

Master-report instruction
Use these pages to add the Lab 10 increment to the existing professional audit report. Apply prior instructor corrections, update the master version history and build register, preserve approved IDs, and submit the complete updated master unless the instructor directs otherwise.

A. Master Report Update Control

A.1 Version History Entry

Version	Date	Lab / Increment	Prepared By	Reviewed By	Change Summary
0.4	[Date]	Lab 10 / Increment 4	Isidro, Daclis, Tinaan	[Reviewers - after cross-review]	Added Control Test Results and Gap Analysis (control inventory, design assessment, test plans, gap register, coverage) and incorporated prior feedback. Test results are pending execution - see Section XXII.

A.2 Final Audit Report Build Register Update

Lab	Report Section	Status	Version / Date	Instructor Action
7	Engagement Profile and Scope	Completed	0.1 / [Lab 7 date]	Approved (per Lab 8 register; confirm)
8	Asset Inventory and System Documentation	Completed	0.2 / [date]	[Approved / Revise / Pending]
9	Risk and Compliance Assessment	Completed	0.3 / [date]	[Approved / Revise / Pending]
10	Control Assessment and Gap Analysis	In Progress	0.4 / [date]	[Approved / Revise / Pending]
11	Audit Findings and Recommendations	Reserved		[Approved / Revise / Pending]
12	AI Validation Portfolio and Final Report Integration	Reserved		[Approved / Revise / Pending]

A.3 Prior Feedback Closure

Feedback ID	Prior Instructor Comment / Required Revision	Action Taken	Section / IDs Affected	Closed By / Date
FB-09-01	Lab 9 reconciliation REC-09-01 (exception): High/Critical risks had no Lab 10 test IDs and no Lab 7 objective (OBJ) links. [Add the instructor comment on Lab 9 if it differs.]	TEST-01 to TEST-13 assigned to cover every High risk (Section 22.1); coverage reconciled in Section 23.2. OBJ links still to be added once the approved Lab 7 OBJ IDs are confirmed.	RSK-01 to RSK-06, RSK-08, RSK-10, RSK-11; TEST-01 to TEST-13	[Member / date]
FB-09-02	REC-09-02 (exception): SMS reminders (RSK-07) and DOH reporting (CMP-11) may be outside the approved Lab 7 scope.	SMS controls (CTL-11, TEST-11) are marked conditional on scope confirmation and no SMS test is run until scope is confirmed. DOH reporting has no control or test in this increment.	RSK-07; CMP-11; CTL-11; TEST-11; GAP-08	[Member / date]
FB-09-03	REC-09-04 and REC-09-08 (exceptions): USR/ORG/DATA reference mismatches, and inconsistent build, version, and evidence cutoff across Labs 7 to 9.	This increment cites ACC IDs and USR-03 to USR-06 and records the build as v1.0 pilot per Lab 8. Tests use only approved demo/test accounts and data; audited build and cutoff must be confirmed before any test is run.	Cover table; ACC-01 to ACC-04; Section 22.2	[Member / date]

Feedback ID	Prior Instructor Comment / Required Revision	Action Taken	Section / IDs Affected	Closed By / Date
FB-09-04	Carried forward from Lab 9 (FB-08-03, FB-08-04): do not treat provider-side or design-only safeguards, or the offline design, as tested controls.	Control status separates Implemented (documented), Partial, Planned, and Not evidenced. No planned or design-only control is rated Effective; offline sync (CTL-09) and backup (CTL-10) stay Not Tested until evidence is obtained.	CTL-09, CTL-10; TEST-09, TEST-10	[Member / date]

XXI. Control Assessment and Gap Analysis

21.1 Control Inventory

CTL ID	Control Objective / Activity	Related RSK / CRT	Owner	Type	Implementation	Frequency / Trigger	Evidence Produced	Status
CTL-01	Restrict each user to the functions and data of the assigned role across MOD-01 to MOD-06, with a separate administrator role.	RSK-01, RSK-02, RSK-04; CMP-05	ORG-01 (owner); ORG-03 (administers)	Preventive	Automated	Per request / each login	EVD-08-01 (role description); EVD-08-04/05 (self-reported). Role matrix not yet obtained.	Implemented (documented; configuration not verified)
CTL-02	Authenticate staff with unique username/password accounts before access (INT-05) to stop shared or unauthorized logins.	RSK-02; CMP-05	ORG-01; ORG-03	Preventive	Automated	Per login	EVD-08-04/05 (self-reported). No password rule, lockout, or timeout configuration evidenced.	Partial (lockout, timeout, password rule not evidenced)
CTL-03	Record login, clinical, and administrative actions in system logs so activity can be attributed to a user (ACC-01 to ACC-04).	RSK-01, RSK-02, RSK-05; CMP-05, CMP-08	ORG-01; ORG-03	Detective	Automated	Continuous (each action)	EVD-08-01 (logging described; extent not verified). No log sample yet.	Partial (extent not verified)
CTL-04	Deactivate user accounts when staff leave the ABTC or change roles.	RSK-04; CMP-05	ORG-01 (clinic head); ORG-03	Preventive	Manual (IT-dependent)	On staff exit	Lab 8 ACC-01 to ACC-03 note. No deactivation record or user list yet.	Implemented (documented; operation not evidenced)
CTL-05	Manage the application database account, SMS gateway API key, and cloud sync credential (ACC-05 to ACC-07).	RSK-05; CMP-05, CMP-07	ORG-03; ORG-02	Preventive	Manual (IT-dependent)	On setup, staff change, or suspected exposure	EVD-08-01, 08-02, 08-06, 08-07 (described). Rotation, revocation, and monitoring not evidenced.	Partial (rotation and revocation not evidenced)
CTL-06	Validate patient registration: required fields and duplicate-patient search before a record is saved (FLOW-01, MOD-01).	RSK-10; CMP-03	ORG-01 (clinical lead); ORG-03	Preventive	Automated	Per transaction	EVD-08-02 (narrative); EVD-08-04 (UAT, 8 respondents).	Implemented (documented; untested)
CTL-07	Compute the PEP dose schedule automatically from the registered exposure data (FLOW-02, MOD-03).	RSK-10; CMP-03	ORG-01 (clinical lead); ORG-03	Preventive	Automated	Per registration / schedule change	EVD-08-02; EVD-08-04.	Implemented (documented; untested)
CTL-08	Deduct vaccine stock automatically when doses are dispensed and alert when stock falls below a threshold (FLOW-03, MOD-04).	RSK-11	ORG-01 (nurse/pharmacy custodian); ORG-03	Preventive / Detective	Automated	Per dispensing; alert at threshold	EVD-08-02; EVD-08-03 (functional description only).	Implemented (documented; untested)

CTL ID	Control Objective / Activity	Related RSK / CRT	Owner	Type	Implementation	Frequency / Trigger	Evidence Produced	Status
CTL-09	Queue registrations and tickets taken offline and synchronize them after reconnection, with local duplicate-patient search (FLOW-06, INT-07).	RSK-09, RSK-08; CMP-03	ORG-01; ORG-03	Corrective	Automated	On reconnection	EVD-08-01 (limitation: conflict resolution not independently tested; FB-08-04).	Partial (design only)
CTL-10	Recover patient and dose records after a server or database failure: planned cloud copy (AST-10) and referenced manual/paper fallback (INT-05).	RSK-08, RSK-06; CMP-06	ORG-02; ORG-01	Corrective	Hybrid	Not documented	EVD-08-01, 08-02 (AST-10 partial/planned). No backup log or restore record.	Planned (not operating)
CTL-11	Protect SMS reminders with HTTPS API calls, an API key, and a local delivery-status log (INT-01, AST-08). Conditional on scope confirmation (REC-09-02).	RSK-07; CMP-02, CMP-07	ORG-01; ORG-04 (provider)	Preventive / Detective	Automated	Per message sent	EVD-08-06 (sprint-plan description only; no delivery log).	Partial (documented only; scope to confirm)
CTL-12	Retain and dispose of patient, schedule, notification, and report records under the clinic record-retention policy referenced in FLOW-01.	RSK-12; CMP-04	ORG-01; ORG-02	Preventive	Manual	Per policy schedule (not provided)	REC-08-04 (policy referenced, not provided).	Not evidenced (policy not provided)

Controls listed are those described, planned, or referenced in Labs 8 and 9. Absent controls are not given CTL IDs (Lab 10 manual, Step 2) and appear as uncontrolled conditions in Section 23.1: no enforced HTTPS (GAP-01), no periodic access review (GAP-02), no segregation or admin-activity review (GAP-03), no provider agreement (GAP-08), no change approval (GAP-13), no incident procedure (GAP-14). "Implemented (documented)" means described in the Lab 8 design record and not yet verified. "Not evidenced" means no evidence was available and is not a conclusion that the control is absent. Lab 7 CRT IDs could not be matched to Lab 8 (see Lab 9 drafting notes); add the approved CRT IDs to the Related RSK / CRT column.

21.2 Design Effectiveness Assessment

CTL ID	Risk / Criterion Addressed	Design Factors Reviewed	Design Rating	Rationale / Gap	Reviewer
CTL-01	RSK-01, RSK-02, RSK-04; CMP-05	Responsibility: ORG-01 owns, ORG-03 administers. Coverage: staff roles USR-03 to USR-06 across MOD-01 to MOD-06. Segregation: ACC-04 holds broad privileges. Exception handling: not stated. Evidence: role matrix not yet seen.	Partially Adequate	Roles can restrict access if enforced. Weaknesses: ACC-04 combines user/role management, configuration, database maintenance, and deployment with no documented separation from access approval (GAP-03); no periodic review (GAP-02); export and report permissions by role not yet seen. Design issue even if no misuse is observed. Re-rate once the role matrix is obtained.	Member 2 (Daclis)
CTL-02	RSK-02; CMP-05	Responsibility: ORG-01 / ORG-03. Coverage: all staff logins. Frequency: per login. Precision: password only. Exception handling: no lockout or timeout defined. Evidence: self-reported only.	Partially Adequate	Unique accounts address shared-credential risk, but the documented design defines no password rule, lockout, session timeout, or second factor, so repeated guessing or an unattended session on a clinic workstation is not addressed (GAP-04).	Member 2 (Daclis)

CTL ID	Risk / Criterion Addressed	Design Factors Reviewed	Design Rating	Rationale / Gap	Reviewer
CTL-03	RSK-01, RSK-02, RSK-05; CMP-05, CMP-08	Responsibility: ORG-03 (setup), ORG-01 (review - not assigned). Coverage: events logged not listed. Precision: fields captured not stated. Segregation: admin can alter logs? unknown. Evidence: logs not yet seen.	Partially Adequate	The design records user and admin actions, but the events covered, fields captured (user, time, action, record), protection of logs from administrator alteration, and any review of the logs are not defined. A detective control with no review does not meet the accountability objective of RSK-01 (GAP-03, GAP-05).	Member 2 (Daclis)
CTL-04	RSK-04; CMP-05	Responsibility: clinic head notifies, administrator deactivates. Coverage: leavers only. Frequency: on exit. Dependencies: manual notice. Evidence: no record produced.	Partially Adequate	Deactivation on exit is a sound preventive step, but it relies on a manual notice, states no timeframe, does not cover role changes or dormant accounts, and produces no record that can be reviewed (GAP-02).	Member 2 (Daclis)
CTL-05	RSK-05; CMP-05, CMP-07	Responsibility: ORG-03 holds and administers. Coverage: three credentials (ACC-05 to ACC-07). Frequency: not defined. Segregation: one party. Dependencies: provider-side credential handling (ORG-04, ORG-05). Evidence: none.	Partially Adequate	Credentials are described as managed, but owner, storage location, rotation interval, revocation on staff change, and monitoring are not defined, and the capstone team both holds and administers them (GAP-06).	Member 3 (Tinaan)
CTL-06	RSK-10; CMP-03	Responsibility: ORG-01 clinical lead. Coverage: registration form (MOD-01). Frequency: per transaction. Precision: required fields and duplicates only. Exception handling: not stated. Evidence: narrative and 8-respondent UAT.	Partially Adequate	Required-field validation and duplicate search would reduce bad or duplicate records if they work as described. Not documented: field-level validity rules (dates, categories), handling of near-duplicates, and who corrects exceptions. A narrative and a small self-developed UAT cannot demonstrate design adequacy (GAP-09).	Member 1 (Isidro)
CTL-07	RSK-10; CMP-03	Responsibility: ORG-01. Coverage: every registration. Precision: depends on rules matching the approved regimen. Segregation: no independent check. Exception handling: none stated. Evidence: narrative.	Partially Adequate	Automated calculation is repeatable if the rules match the ABTC-approved regimen, but the design includes no independent clinician confirmation of the generated schedule and no comparison of the rules to the approved regimen. One computation is the single safeguard for a patient-safety risk (GAP-09).	Member 2 (Daclis)
CTL-08	RSK-11	Responsibility: nurse/pharmacy custodian. Coverage: normal dispensing. Frequency: per dispensing. Precision: wastage, return, expiry not covered. Exception handling: not stated. Evidence: functional description.	Partially Adequate	Deduction and a low-stock alert cover routine dispensing, but the design does not cover wastage, returns, expiry, or reconciliation to a physical count, so system stock can drift from physical stock. Alert threshold owner not stated (GAP-10).	Member 1 (Isidro)

CTL ID	Risk / Criterion Addressed	Design Factors Reviewed	Design Rating	Rationale / Gap	Reviewer
CTL-09	RSK-09, RSK-08; CMP-03	Responsibility: ORG-03 / ORG-01. Coverage: offline registrations and tickets. Frequency: on reconnection. Precision: conflict rule not defined. Exception handling: no reconciliation report. Evidence: design only (FB-08-04).	Partially Adequate	Queuing preserves offline entries, but without a conflict-resolution rule or reconciliation report, duplicates or overwrites after reconnection would not be detected or corrected (GAP-11).	Member 1 (Isidro)
CTL-10	RSK-08, RSK-06; CMP-06	Responsibility: ORG-02 / ORG-01. Coverage: cloud copy partial/planned. Frequency: not documented. Exception handling: no restore procedure. Dependencies: connectivity and provider. Evidence: none.	Inadequate	AST-10 is partial/planned, and no scheduled local backup, restore procedure, monitoring, or downtime procedure is documented. A planned feature does not reduce RSK-08, and the design as documented would not allow timely restoration (CMP-06). Operating effectiveness is a separate question and stays Not Tested (GAP-07).	Member 3 (Tinaan)
CTL-11	RSK-07; CMP-02, CMP-07	Responsibility: ORG-01; provider ORG-04 outside ABTC control. Coverage: all reminders. Precision: message-content rule not documented. Exception handling: no automatic fallback (INT-01). Dependencies: internet and provider. Evidence: sprint plan only.	Partially Adequate	HTTPS, an API key, and a delivery-status log suit the channel, but there is no fallback for failed delivery, no review of the log, and no documented rule limiting message content. Provider-side controls cannot be assessed. Conditional on scope (REC-09-02) (GAP-08).	Member 3 (Tinaan)
CTL-12	RSK-12; CMP-04	Responsibility: ORG-01 / ORG-02. Coverage: unknown. Frequency: unknown. Evidence: policy referenced but not provided.	Not Assessed	The retention policy referenced in FLOW-01 was not provided, so the design cannot be assessed. This is an evidence limitation, not a conclusion that the control is inadequate (GAP-12).	Member 3 (Tinaan)

Design ratings use only the documented design (Lab 8 and Lab 9 evidence) and say nothing about whether a control operated. Re-rate after the walkthrough, role matrix, and configuration evidence are obtained.

XXII. Control Test Workpapers

22.1 Test Plan and Results

TEST ID	CTL / RSK	Population / Period	Sample Method / Size	Procedure	Expected Result	Actual Result / Exceptions	Evidence	Conclusion
TEST-01	CTL-01 / RSK-01, RSK-02, RSK-04	Role-function combinations for the staff roles (ACC-01 to ACC-04) across MOD-01 to MOD-06 in the approved demo/test environment, on the test date [date].	Full population: every role x every function in the role matrix ([N] combinations).	Tester: Member 2. Obtain role matrix and user-role mapping. Using one approved test account per role, attempt each function and each restricted record view, including export/report and user management. Record allowed or denied and compare to the matrix. No real credentials; no bypass attempts.	Each role performs only its approved functions; out-of-role attempts are denied; only the administrator manages users and roles.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-01 (sanitized role matrix; test-account result screenshots)	Not Tested (pending execution)

TEST ID	CTL / RSK	Population / Period	Sample Method / Size	Procedure	Expected Result	Actual Result / Exceptions	Evidence	Conclusion
TEST-02	CTL-02 / RSK-02	Authentication settings and one test account per role at the test date [date].	All settings; 1 test account per role; lockout test on 1 dedicated account ([N] failed attempts).	Tester: Member 2. Inspect password rule. Try a weak password on a test account. Make [N] failed logins on a dedicated test account and note lockout or delay. Leave a test session idle and record the timeout. Check whether one account can be used at once from two workstations. Repeat on a second account (reperformance).	A password rule is enforced; repeated failures lock or delay the account; idle sessions end after a defined time; each user has an own account. State the criterion used [CRT confirm].	[Tester to record observed result and number of exceptions after execution.]	EVD-10-02 (sanitized settings and login-behavior screenshots)	Not Tested (pending execution)
TEST-03	CTL-03 / RSK-01, RSK-05	Log entries for 6 defined action types during the test session: login, failed login, patient create, dose-record edit, user/role change, configuration change.	All 6 action types, 1 occurrence each, performed by named test accounts.	Tester: Member 2; reviewer Member 3. Perform each action, then inspect the log for who, when, and what. Check by inspection on test data whether an administrator can edit or delete log entries. Ask whether logs are reviewed and obtain any review record.	Each action creates an attributable entry; ordinary users cannot alter logs; evidence of administrator-activity review exists.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-03 (sanitized log extract; review record if any)	Not Tested (pending execution)
TEST-04	CTL-04 / RSK-04	All user accounts at the evidence cutoff compared with the current ABTC staff roster.	Full population ([N] accounts) plus 1 deactivated test account.	Tester: Member 2. Obtain a sanitized user list and the staff roster from ORG-01. Match each account to a current staff member and role; list leavers, dormant accounts, and role mismatches. Request the exit-notification record. Attempt login with a test account deactivated for this test.	No active account for a departed staff member; each role matches current duties; a deactivated account cannot log in.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-04 (sanitized user list and roster comparison)	Not Tested (pending execution)
TEST-05	CTL-05 / RSK-05	Credentials ACC-05 to ACC-07 (database account, SMS API key, cloud sync credential): configuration and records at cutoff.	Full population (3 credentials).	Tester: Member 3 with ORG-03. With secret values masked, inspect where each credential is held, the privilege level of the database account, and any rotation or revocation record. Do not copy any secret into the report.	Credentials are not visible to general users; the database account is least-privilege; rotation or revocation records exist or a schedule is documented.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-05 (masked configuration screenshots)	Not Tested (pending execution)

TEST ID	CTL / RSK	Population / Period	Sample Method / Size	Procedure	Expected Result	Actual Result / Exceptions	Evidence	Conclusion
TEST-06	CTL-06 / RSK-10	All required fields on the registration form (MOD-01) and the duplicate-patient search.	Each required field tested blank once (100%); 3 duplicate scenarios using demo records.	Tester: Member 1. Using demo data, submit the form with each required field blank and with invalid formats. Register the same demo patient as an exact duplicate, a spelling/spacing variant, and same name with a different birth date. Record whether each was saved, rejected, or flagged.	Incomplete or invalid entries are rejected with a message; duplicates are flagged for staff action.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-06 (demo-data screenshots)	Not Tested (pending execution)
TEST-07	CTL-07 / RSK-10	PEP schedules generated for each exposure category in the ABTC-approved regimen [list categories].	Judgmental: every category x [N] exposure dates, including a month-end date and a weekend/holiday date.	Tester: Member 2; reviewer Member 3. Obtain the ABTC-approved schedule from ORG-01. Calculate expected dose dates independently first. Register demo patients with the same exposure data, record the generated schedule, and compare each date.	Generated schedule equals the independently calculated schedule for all cases (0 exceptions).	[Tester to record observed result and number of exceptions after execution.]	EVD-10-07 (case list, expected vs generated dates)	Not Tested (pending execution)
TEST-08	CTL-08 / RSK-11	Demo stock batches for each vaccine item in MOD-04, test environment.	Judgmental: [N] batches; [N] doses dispensed; 1 below-threshold case; 1 wastage/expiry case.	Tester: Member 1. Record opening stock, dispense doses through demo patients, and compare the system balance with the expected balance. Lower stock below the threshold and observe the alert. Attempt a wastage or expiry adjustment and note whether it is supported and logged.	Balance falls by the exact doses dispensed; alert appears at the threshold; adjustments are supported and logged with user and reason.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-08 (before/after stock screenshots)	Not Tested (pending execution)
TEST-09	CTL-09 / RSK-09, RSK-08	Offline-to-online synchronization events in the demo environment.	[N] scenarios: new record offline; same patient edited on two nodes; duplicate created offline.	Tester: Member 1. Demo environment only, never production. If offline mode is not available in the audited build, record Not Tested with the reason. Disconnect, make edits, reconnect, and review the resulting records for duplicates, overwrites, and any reconciliation report.	Synchronized records are complete; conflicts follow a defined rule or are flagged; no silent overwrite.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-09 (before/after record views)	Not Tested (pending execution)

TEST ID	CTL / RSK	Population / Period	Sample Method / Size	Procedure	Expected Result	Actual Result / Exceptions	Evidence	Conclusion
TEST-10	CTL-10 / RSK-08, RSK-06	Backup configuration, backup logs, and restore records for the local database and AST-10 at cutoff, period [dates].	All available backup records for the period; 1 restore of a demo-data backup to a separate test instance if authorized.	Tester: Member 3 with ORG-02/ORG-03. Request backup schedule, the last [N] backup logs, and any restore record. Inspect AST-10 status. If authorized and feasible, restore a demo-data backup to a separate test instance and compare record counts. Never overwrite production data.	Backups run on schedule and are monitored; a restore succeeds with matching record counts in a stated time.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-10 (backup log extract; restore record)	Not Tested (pending execution)
TEST-11	CTL-11 / RSK-07	Reminder messages sent in the demo environment to team-owned test numbers, and the delivery-status log.	[N] test messages (suggest 5), including 1 failure case if feasible.	Tester: Member 3. Run only after scope is confirmed (REC-09-02). Send reminders to team-owned numbers, match each to the delivery-status log, review the message text for diagnosis or treatment detail, and record how failures are handled.	Each message appears in the log with a status; failures are identifiable; message text has no diagnosis details.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-11 (log extract; message template)	Not Tested (pending execution)
TEST-12	CTL-12 / RSK-12	Retention policy and the record categories AST-04 to AST-06, AST-09, and AST-10 (including cloud and archive copies).	All 5 record categories compared with the policy.	Tester: Member 3. Request the retention policy and disposal procedure from ORG-01/ORG-02. Map each record category to a retention period and disposal method and check whether cloud and archive copies are covered. If the policy is not provided, record an evidence limitation.	Policy states a period and disposal method for each category, including copies.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-12 (policy extract or request log)	Not Tested (pending execution)
TEST-13	None (uncontrolled) / RSK-03	Staff-to-application access path (DEP-02) in the test environment at the test date.	All staff login URLs ([N]): 1 HTTPS and 1 HTTP request each.	Tester: Member 2. Inspect web-server TLS settings (sanitized). Open the login page over HTTPS and over HTTP using a test account only; record the certificate status and whether HTTP is redirected or refused. No traffic interception or capture.	All staff access uses HTTPS with a valid certificate; plain HTTP is redirected or refused.	[Tester to record observed result and number of exceptions after execution.]	EVD-10-13 (sanitized TLS settings; browser screenshots)	Not Tested (pending execution)

Actual results are intentionally blank: no test has been performed in this draft. Each conclusion stays Not Tested until the tester records the observed result, exceptions, and sanitized evidence (EVD-10-xx). Tests use approved test accounts and demo or de-identified data only. Tester assignments: Member 1 (TEST-06, 08, 09), Member 2 (TEST-01, 02, 03, 04, 07, 13), Member 3 (TEST-05, 10, 11, 12).

22.2 Detailed Test Note / Reperformance Record

Selected TEST ID: TEST-02 - Authentication controls (CTL-02 / RSK-02; Lab 9 treatment: test in Lab 10)

Tester / reviewer: Member 2 (Daclis) / reperformed by Member 1 (Isidro) - see REV-10-01.
Date / time and environment: [record date and time] | [demo/test environment and build version - confirm per REC-09-08].
Authorization: [record the ORG-01 authorization or Lab 7 scope reference allowing test accounts in this environment]. Test accounts only; no real staff credentials; nothing run against production.
Exact procedure: (1) Obtain and sanitize the authentication settings (password rule, lockout, session timeout). (2) On one test account, try a password that breaks the stated rule and record whether it is accepted. (3) On a dedicated test account, make [N] consecutive failed logins and record whether the account is locked or delayed and how it is released. (4) Log in with a test account, leave the session idle, and record the time until it ends. (5) Check whether the same account can be used from two workstations at once. (6) Repeat steps 3 and 4 on a second test account.
Sample identifiers: test accounts [TA-01, TA-02] (anonymized references; no real usernames).
Actual observations: [Record exactly what happened at each step, including unexpected results. Do not rewrite results to match the expected outcome.]
Exceptions and handling: [Number of exceptions; link each to GAP-04 or document it as not material with rationale.]
Evidence IDs: EVD-10-02 [sanitized screenshots of settings and login behavior; no passwords or tokens].
Limitation: [For example: single test date, so operation over the whole period is not shown; production configuration not inspected.]
Reviewer / reperformance result: [Reviewer name, date, same or different result].
Final conclusion: [Effective / Partially Effective / Ineffective / Not Tested, with reason. Remains Not Tested until the steps are performed.]

Selected TEST ID: TEST-07 - PEP schedule computation (CTL-07 / RSK-10; Lab 9 treatment: test in Lab 10)

Tester / reviewer: Member 2 (Daclis) / reviewed by Member 3 (Tinaan). [Add clinical-lead confirmation from ORG-01 if available.]
Date / time and environment: [record date and time] | [demo/test environment and build version - confirm per REC-09-08].
Authorization: [record the ORG-01 authorization or Lab 7 scope reference]. Demo or de-identified data only; no real patient records.
Exact procedure: (1) Obtain the ABTC-approved PEP schedule from ORG-01 and list its exposure categories and rules. (2) Select cases: every category x [N] exposure dates, including a month-end date and a weekend/holiday date. (3) Before using the system, calculate the expected dose dates for each case. (4) Register demo patients with the same exposure data and record the schedule generated. (5) Compare each generated date with the expected date and record every difference. (6) The reviewer repeats at least [2] cases.
Sample identifiers: demo patient references [DP-01 to DP-nn]; state the regimen document and version used.
Actual observations: [Record expected vs generated dates for each case, exactly as seen.]
Exceptions and handling: [Number of differences; link to GAP-09. Any difference affects patient safety and should be raised with the Control Assessment Lead immediately.]
Evidence IDs: EVD-10-07 [case list and expected vs generated dates; screenshots with demo data only].
Limitation: [For example: judgmental sample; does not prove behavior for every date or category; regimen version reviewed].
Reviewer / reperformance result: [Reviewer name, date, same or different result].
Final conclusion: [Effective / Partially Effective / Ineffective / Not Tested, with reason. Remains Not Tested until the steps are performed.]

XXIII. Gap Analysis and Control Coverage

23.1 Gap Register

GAP ID	Affected CTL / TEST	Related RSK / CMP / CRT	Gap or Limitation	Evidence	Impact / Priority	Owner	Candidate Finding?
GAP-01	TEST-13 (no CTL)	RSK-03; CMP-05	Uncontrolled risk: staff access to the application uses HTTPS only as a recommendation (DEP-02); no enforcement or TLS configuration evidence.	DEP-02; EVD-08-04; EVD-10-13 (pending)	Credentials and health data could be intercepted or altered on the network. Impact 5 / H.	ORG-01; ORG-02	Yes (provisional) - supported by the DEP-02 wording; confirm with TEST-13 before Lab 11.
GAP-02	CTL-04, CTL-01; TEST-04	RSK-04; CMP-05, CMP-10	Missing control: no periodic user-access or privilege review; deactivation on exit has no record or timeframe.	Lab 8 ACC-01 to ACC-03 (review cadence not documented); EVD-10-04 (pending)	Dormant or over-privileged accounts keep access to patient records. Impact 4 / H.	ORG-01 (clinic head)	Yes (provisional) - documented absence; confirm by inquiry and TEST-04.
GAP-03	CTL-01, CTL-03; TEST-01, TEST-03	RSK-01; CMP-05	Design gap: ACC-04 holds broad privileges with no documented separation between access approval and administration, and no review of administrator activity.	Lab 8 ACC-04 (SoD evidence limited); EVD-10-01, EVD-10-03 (pending)	Undetected or unattributable changes to patient and dose records. Impact 5 / H.	ORG-01; ORG-03	Pending - re-screen after TEST-01 and TEST-03.
GAP-04	CTL-02; TEST-02	RSK-02; CMP-05	Design gap: no password rule, lockout, session timeout, or second factor defined or evidenced for password-only login.	INT-05; EVD-08-04/05 (self-reported); EVD-10-02 (pending)	Stolen, guessed, or shared credentials give access to patient data. Impact 5 / H.	ORG-01; ORG-03	Pending - TEST-02 result decides.
GAP-05	CTL-03; TEST-03	RSK-01, RSK-05; CMP-08	Evidence limitation: extent and protection of logs not verified, and logs not shown to be reviewed.	EVD-08-01; EVD-10-03 (pending)	Accountability and breach detection depend on usable logs. Impact 4 / H.	ORG-03; ORG-01	No - evidence limitation until TEST-03 is performed.
GAP-06	CTL-05; TEST-05	RSK-05; CMP-05, CMP-07	Not evidenced: no rotation, revocation, least-privilege database account, or monitoring shown for ACC-05 to ACC-07.	EVD-08-01/02/06/07; EVD-10-05 (pending)	A leaked credential would bypass application role controls. Impact 5 / H.	ORG-03; ORG-02	Pending - TEST-05 result decides.
GAP-07	CTL-10; TEST-10	RSK-08; CMP-06	Missing operating control: cloud copy is partial/planned; no backup log, restore test, or downtime procedure.	AST-10 (partial/planned); INT-02; EVD-10-10 (pending)	Loss or prolonged unavailability of dose records; missed or duplicated doses. Impact 4 / H.	ORG-02; ORG-01	Yes (provisional) - planned control documented as not operating; confirm in TEST-10.

GAP ID	Affected CTL / TEST	Related RSK / CMP / CRT	Gap or Limitation	Evidence	Impact / Priority	Owner	Candidate Finding?
GAP-08	CTL-11, CTL-05; TEST-11	RSK-06, RSK-07; CMP-07	Evidence limitation: no agreement or security statement for the cloud (ORG-05) and SMS (ORG-04) providers; SMS scope unconfirmed (REC-09-02); no fallback for failed reminders.	DEP-04, DEP-05; LIM-01; EVD-08-06; EVD-10-11 (pending)	Patient data and contact numbers processed outside ABTC control. Impact 5 (cloud), 3 (SMS) / H (cloud), M (SMS).	ORG-01 with LGU legal/DPO	No - evidence limitation; re-screen when provider evidence is obtained.
GAP-09	CTL-06, CTL-07; TEST-06, TEST-07	RSK-10; CMP-03	Untested: validation and PEP schedule computation are described only; no independent clinician confirmation of generated schedules.	EVD-08-02, EVD-08-04; EVD-10-06, EVD-10-07 (pending)	Missed, delayed, or incorrect post-exposure doses. Impact 5 / H.	ORG-01 (clinical lead); ORG-03	Pending - strongest candidate if TEST-07 shows any exception.
GAP-10	CTL-08; TEST-08	RSK-11	Untested, with design gap: stock deduction and alerting untested; wastage, return, expiry adjustments and physical reconciliation not defined.	EVD-08-03; EVD-10-08 (pending)	Stock-out or use of expired vaccine. Impact 4 / H.	ORG-01 (nurse/pharmacy custodian)	Pending - TEST-08 result decides.
GAP-11	CTL-09; TEST-09	RSK-09; CMP-03	Design-only control: no conflict-resolution rule or reconciliation report; offline sync untested.	FLOW-06; INT-07; EVD-10-09 (pending)	Duplicate or overwritten records after reconnection. Impact 4 / M.	ORG-01; ORG-03	No - pending TEST-09.
GAP-12	CTL-12; TEST-12	RSK-12; CMP-04	Evidence limitation: retention policy referenced but not provided; no disposal method for cloud and archive copies.	REC-08-04; EVD-10-12 (pending)	Records kept longer than necessary; privacy exposure. Impact 3 / M.	ORG-01; ORG-02	No - obtain the policy first.
GAP-13	No CTL (none tested)	RSK-13	Uncontrolled risk (assumption): no change approval, second-person review, or post-project support arrangement evidenced for deployment and maintenance by the capstone team (ORG-03).	Lab 9 assumption, not stated in Lab 8; confirm with ORG-01	Unreviewed changes could cause defects or exposure. Impact 3 / M.	ORG-01	No - the assumption must be confirmed first.
GAP-14	No CTL (none tested)	CMP-08, CMP-10; RSK-01, RSK-05, RSK-06	Evidence limitation: no incident-response or breach-notification procedure and no data protection officer designation obtained.	CMP-08, CMP-10 (Not Determined in Lab 9)	A breach may not be detected, escalated, or notified. Impact 4 / M.	ORG-02 (LGU Health Office)	No - request the procedure and DPO record.

23.2 Control Domain Coverage Summary

Control Domain	Relevant Risks	Controls Identified	Tests Performed	Effective / Partial / Ineffective / Not Tested	Material Gaps / Limits
Access control and authentication	RSK-01, RSK-02, RSK-04, RSK-05	4 / CTL-01, 02, 04, 05	0 of 4 performed / TEST-01, 02, 04, 05 planned	0 / 0 / 0 / 4	GAP-02, 03, 04, 06

Control Domain	Relevant Risks	Controls Identified	Tests Performed	Effective / Partial / Ineffective / Not Tested	Material Gaps / Limits
Logging and monitoring	RSK-01, RSK-05	1 / CTL-03	0 of 1 performed / TEST-03 planned	0 / 0 / 0 / 1	GAP-03, 05
Application processing	RSK-09, RSK-10, RSK-11	4 / CTL-06 to CTL-09	0 of 4 performed / TEST-06 to 09 planned	0 / 0 / 0 / 4	GAP-09, 10, 11
Transmission / infrastructure	RSK-03	0 (uncontrolled)	0 of 1 performed / TEST-13 planned	0 / 0 / 0 / 1	GAP-01
Backup and recovery	RSK-06, RSK-08	1 / CTL-10	0 of 1 performed / TEST-10 planned	0 / 0 / 0 / 1	GAP-07
Third-party / interface	RSK-06, RSK-07	1 / CTL-11 (CTL-05 for credentials)	0 of 1 performed / TEST-11 planned	0 / 0 / 0 / 1	GAP-08 (no control identified for the cloud provider relationship)
Data privacy and retention	RSK-12	1 / CTL-12	0 of 1 performed / TEST-12 planned	0 / 0 / 0 / 1	GAP-12
Change, incident, and governance	RSK-13; CMP-08, CMP-10	0 (none evidenced)	0 - no control to test; evidence requested	n/a	GAP-13, GAP-14 (limitations; not tested)

High-risk mapping: RSK-01 (CTL-01, CTL-03; GAP-03, GAP-05); RSK-02 (CTL-01, CTL-02, CTL-03; GAP-04); RSK-03 (uncontrolled; GAP-01); RSK-04 (CTL-01, CTL-04; GAP-02); RSK-05 (CTL-03, CTL-05; GAP-06); RSK-06 (CTL-05, CTL-10; GAP-08); RSK-08 (CTL-10; GAP-07); RSK-10 (CTL-06, CTL-07; GAP-09); RSK-11 (CTL-08; GAP-10). Tests performed in this draft: 0 of 13 planned.

XXIV. Lab 10 Completion Checklist

Check	Completion Requirement
[x]	Every high-priority risk maps to a control or an explicit uncontrolled-gap record. (RSK-01 to RSK-06, RSK-08, RSK-10, RSK-11 mapped in Sections 21.1 and 23.1; see mapping note under Section 23.2.)
[x]	Control design and operating effectiveness are assessed separately. (Design: Section 21.2. Operation: Section 22.1.)
[ ]	Every test records population/period, sample, authorized procedure, expected result, actual result, evidence, exceptions, limitation, and conclusion. (Plans complete; actual results, exceptions, and conclusions pending execution.)
[ ]	Every exception is resolved, linked to a gap, or documented as not material with rationale. (Pending test results.)
[ ]	Control ratings use the defined basis, do not treat planned controls as operating, and are supported by cross-review or reperformance, AI validation, version control, and attestation. (Basis applied; cross-review, AI validation, and attestation pending.)

Z. Collaboration, AI Validation, and Instructor Review

Z.1 Cross-Member Challenge Record

Review ID	Prepared By	Reviewed By	Item / Section	Challenge or Check	Resolution / Evidence
REV-10-01	Member 2 (Daclis)	Member 1 (Isidro)	TEST-02; CTL-02	Reperformance: repeat the lockout and idle-timeout steps on a different test account and compare. Is the criterion for an acceptable lockout and timeout stated and sourced (CRT or ABTC/LGU policy)?	[Reviewer to record.] Draft position: take the criterion from the approved Lab 7 CRT or ABTC/LGU policy; if none exists, state the baseline used and its source.
REV-10-02	Member 3 (Tinaan)	Member 2 (Daclis)	CTL-10; TEST-10; GAP-07	Challenge: is a design rating of Inadequate justified for a planned control, and does the operating conclusion stay Not Tested until backup evidence is requested and received? Does any restore use only a separate test instance?	[Reviewer to record.] Draft position: Inadequate rests on AST-10 being documented as partial/planned; the operating conclusion stays Not Tested.
REV-10-03	Member 2 (Daclis)	Member 3 (Tinaan)	TEST-01; CTL-01; GAP-03	Challenge: does the tested population come from the actual role matrix, and is the broad ACC-04 privilege treated as a design gap even if no misuse is observed?	[Reviewer to record.] Draft position: population must be taken from the obtained role matrix; ACC-04 remains a design issue regardless of observed misuse.

Z.2 Human-in-the-Loop AI Validation Log

AI ID	Tool / Purpose	Material Suggestion	Evidence / Criteria Checked	Decision	Correction / Rationale	Privacy Check
AI-10-01	Claude (Anthropic AI assistant) / first draft of control inventory and classification	Proposed 12 controls (CTL-01 to CTL-12) with type, nature, frequency, and status from Lab 8 and Lab 9 descriptions	Lab 8 and Lab 9 registers (ACC, INT, DEP, FLOW, EVD, RSK, CMP); Lab 10 manual Steps 2-3 (no invented controls)	[Pending: Accept / Revise / Reject per control]	[Human judgment and final action - confirm each control against the actual build]	Only Lab 9 report text and Lab 10 manual/template supplied; no credentials or patient data [group to confirm]
AI-10-02	Claude / design ratings and test plans	Proposed design ratings (Section 21.2) and test populations, samples, procedures, and expected results (Section 22.1)	Lab 10 manual Steps 4-6; Lab 7 authorized-testing limits; actual capstone behavior	[Pending]	[Human judgment and final action]	No sensitive data supplied [group to confirm]
AI-10-03	Claude / gap wording and coverage mapping	Drafted GAP-01 to GAP-14, provisional candidate-finding view, and the domain coverage summary	Lab 9 RSK/CMP records; test evidence (none available yet); Lab 10 Steps 8-9	[Pending]	[Human judgment and final action]	No sensitive data supplied [group to confirm]

Z.3 Group Attestation

We certify that the Lab 10 work reflects the identified capstone build and authorized evidence. We completed the assigned work and cross-review, protected confidential information, did not treat AI output as audit evidence, and disclosed material limitations.

Member	Printed Name	Signature	Date
Member 1	Edmar A. Isidro		
Member 2	Celso L. Daclis		
Member 3	Alvin T. Tinaan		

Z.4 Instructor Review

Review Area	Status	Instructor Notes
Master-report continuity and prior feedback	[ ] Approved [ ] Revise	
Technical completeness and traceability	[ ] Approved [ ] Revise	
Evidence, limitations, collaboration, AI validation, and professional judgment	[ ] Approved [ ] Revise	

Instructor disposition and required revisions: Record the decision and detailed comments in the Instructor Notes column above or on the institution's grading sheet.

Drafting Notes for the Group (remove before submission)

1. Test results are intentionally not filled in. No test was run to produce this draft, so every Actual Result cell is blank and every conclusion is Not Tested (pending execution). Perform the tests, record what you actually observe, attach sanitized EVD-10-xx evidence, and only then change a conclusion to Effective, Partially Effective, or Ineffective.

2. Complete every [N] and [date] placeholder with the real population, sample size, and test date. Use only approved test accounts and demo or de-identified data (Lab 7 authorizes demo data only). Mask passwords, tokens, and keys in screenshots.

3. Resolve REC-09-02 (SMS and reporting scope) and REC-09-08 (build, version, evidence cutoff) first. They affect CTL-11, TEST-11, GAP-08 and the cover table.

4. The controls come only from Lab 8 and Lab 9 evidence, so "Implemented (documented)" means described, not verified. Confirm each control against the actual build before submitting. Add or remove controls as the build requires, and keep every ID you keep.

5. Replace remaining placeholders: group number, dates, instructor comments on Lab 9 (A.3), approved CRT and OBJ IDs, and approval dates.

6. The template build register and sample IDs used Labs 9 to 14 and the 12 series (FB-12, REV-12, AI-12). This draft follows the Lab 9 numbering (Labs 7 to 12) and uses the 09 and 10 series.

7. The template assigns roles by member number. In Lab 9, Daclis was the Compliance and Privacy Analyst and Tinaan the Technical Risk and Evidence Analyst. Swap the Member 2 and Member 3 test assignments if that fits your group better, but keep the manual cross-check rule: Member 1 reperforms a test by another member, Member 2 challenges a governance or recovery conclusion, Member 3 challenges an access or application test.

8. REV and AI rows are drafts. Each member must perform the challenge, record the real resolution, decide each AI entry, and sign the attestation.

9. "Yes (provisional)" in Candidate Finding marks gaps already supported by documented design evidence. Lab 11 makes the final screening decision.

10. Rename the file as your instructor requires and delete this page before submission.